Information Security Management System (ISMS) Roles & Responsibilities

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This document defines and assigns the roles and responsibilities necessary for the effective implementation, maintenance, and continual improvement of Stark Industries Inc.'s Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 5.3.

Scope

This document applies to all personnel and functions within the ISMS scope, covering individuals directly responsible for or contributing to the security of information assets and operations associated with Stark Industries Inc.’s SaaS marketing platform.

Key Roles and Responsibilities

- Chief Executive Officer (CEO): Tony Stark
    - Has overall accountability for the ISMS.
    - Ensures alignment of the ISMS with strategic objectives.
    - Provides necessary resources for the ISMS.

- Approves the Information Security Policy and key ISMS decisions.

- Information Security Manager: Happy Hogan
  - Leads the implementation and maintenance of the ISMS.
  - Oversees risk management, control implementation, audits, and improvement activities.
  - Ensures ISMS compliance with ISO/IEC 27001:2022.
  - Reports ISMS performance to top management.
  - Coordinates incident response and internal awareness programs.

- Cyber Security GRC Analyst: Lolade Oluwole
  - Manages governance, risk, and compliance processes.

- Develops and maintains ISMS documentation (policies, risk assessments, SoA).

- Conducts internal audits and coordinates with external auditors.

- Tracks corrective actions and compliance metrics.

- Information Security Analyst: James Rhodes
  - Monitors security events and alerts.

  - Supports threat detection, incident handling, and vulnerability management.

  - Performs day-to-day technical security tasks (e.g., log reviews, endpoint monitoring).

- IT Infrastructure Engineer: Maria Hill
  - Manages cloud infrastructure security (e.g., AWS configuration, access control).

  - Implements technical controls for network, systems, and endpoints.

- Supports backup and recovery processes.

- Software Developer: Natalia Romanoff
  - Applies secure coding practices in application development.
  - Participates in secure software development lifecycle (SSDLC).
  - Addresses vulnerabilities found during code reviews or scans.

- All Employees and Contractors
  - Must adhere to information security policies and procedures.
  - Are responsible for protecting company information and reporting security incidents.
  - Participate in awareness training and apply best practices.

Authority Delegation

The CEO delegates day-to-day responsibility for the ISMS to the Information Security Manager but retains overall accountability. All role holders must operate within their defined authority and escalate security concerns to the appropriate level.